

BSI Banco Santander International Technology



PAM Definition of Privilege

Document History and Version Control

Ownership and Authorship

Version	Date	Author	Owner	Change
1.0	3/19/2019	PAM US	CISO	Initial Version
2.0	4/26/2021	BSI Infosec	CyberSecurity Compliance Officer	3.2 CyberArk – added Privileged accounts: - mia.usa.sinvest\PSG_printing – Use of local printers group - mia.usa.sinvest\CyberArk_Alero_Users – Third Party vendor/consultant users
3.0	11/24/2021	BSI Infosec	CyberSecurity Compliance Officer	3.2 CyberArk – added Privileged groups: - mia.usa.sinvest\CISCO ISE Administrators - mia.usa.sinvest\CISCO Network Administrators
4.0	4/12/2022	BSI Infosec	CyberSecurity Compliance Officer	3.2 CyberArk – network privileged Privileged groups: - mia.usa.sinvest\ISEAdmin - mia.usa.sinvest\F5FullAdmin
5.0	6/23/22	BSI Infosec	CyberSecurity Compliance Officer	Correction in the name of 2 domain privileged groups: - From Globus_ReadOnly_Operators to Globus_ReadOnly - From “Infosec Auditors” to “Cyberark_Auditors”
6.0	5/25/23	BSI Infosec	CyberSecurity Compliance Officer	Removed reference to SOX PAM Definition of Privilege to PAM Definition of Privilege.
7.0	11/03/23	BSI Infosec	CyberSecurity Compliance Officer	Added a new privileged AD group in section 3.2: Appian Admin Support
8.0	12/18/2023	BSI Infosec	CyberSecurity Compliance Officer	Replaced group ITGS – Support with ITGS in section 3.2 Added a new section 3.5 to include MYSQL database instance permissions. All other sections were sequentially updated. Removed reference to AIX in section 3.7.

9.0	1/24/2025	BSI Infosec	CyberSecurity Compliance Officer	Added a new privileged AD group in section 3.2: Cyberark_RPA_Production Security Group.
10.0	3/11/2025	BSI Infosec	CyberSecurity Compliance Officer	- Added a new privileged AD group in section 3.2: vSphere Administrators - Removed reference to the following documents: Banco Santander International Privileged Access Management Rulebook (PAM Definition); Banco Santander International Privileged Access Management Green List and Banco Santander International Privileged Access Management White List

Sign Off

Approval Body/Individual	Action	Date
Dayam Borges	Approve	

TABLE OF CONTENTS

TABLE OF CONTENTS4

1 INTRODUCTION.....5

1.1 PURPOSE OF THIS DOCUMENT5

1.2 SCOPE AND PERIMETER5

2 PROCEDURE REQUIREMENT5

3 PLATFORMS5

3.1 ACTIVE DIRECTORY5

3.2 CYBERARK6

3.3 NETWORK ADMINISTRATION7

3.4 MSSQL7

3.5 MYSQL7

3.6 ORACLE8

3.7 UNIX & LINUX9

3.8 WINDOWS LOCAL9

3.9 JBASE / T24 / GLOBUS.....10

4 RELATED DOCUMENTS.....10

5 APPENDIX11

5.1 APPENDIX A – KEY CONTACTS.....11

5.2 GLOSSARY11

1 INTRODUCTION

1.1 Purpose of this Document

The purpose of this document is to document the definition of privilege for infrastructure platforms used.

1.2 Scope and Perimeter

This Procedure is applicable to Banco Santander International (BSI) the entity. It applies to all groups managing Santander IT Systems, as well as, to all information assets with existing privileged accounts leveraged in BSI related infrastructure platforms and servers.

2 PROCEDURE REQUIREMENT

This Procedure must be followed when certifying privileged access on servers and databases. This process ensures integrity of BSI information assets.

3 PLATFORMS

This section describes the significant roles and their overall responsibilities in the PAM Provisioning process.

3.1 Active Directory

The following Domains are in scope for the PAM certification:

- BSI_US

Within these domains, users and groups with privileged access include:

- **Domain Admins**
 - Members of this group have full control of the domain. By default, this group is a member of the Administrators group on all domain controllers, all domain workstations, and all domain member servers at the time they are joined to the domain. By default, the Administrator account is a member of this group. Because the group has full control in the domain, access is considered privileged.
- **Enterprise Admins**
 - Members of this group have full control of all domains in the forest. By default, this group is a member of the Administrators group on all domain controllers in the forest. By default, the Administrator account is a member of this group. Because this group has full control of the forest, access is considered privileged.

- **Schema Admins**

- Members of this group can modify the Active Directory schema. By default, the Administrator account is a member of this group. Because this group has significant power in the forest, access is considered privileged.

Domain Controllers:

- **Account Operators**

- Members of this group can create, modify, and delete accounts for users, groups, and computers located in the Users or Computers containers and organizational units in the domain, except the Domain Controllers organizational unit. Members of this group do not have permission to modify the Administrators or the Domain Admins groups, nor do they have permission to modify the accounts for members of those groups. Members of this group can log on locally to domain controllers in the domain and shut them down. Because this group has significant power in the domain, access is considered privileged.

3.2 CyberArk

All users with access to the consoles with the following roles:

- Administrators – Full access to all safes and administration of the tool
- Globus_COB_Operators – Application specific password operations
- Globus_ReadOnly – Application specific password operations
- Cyberark_Auditors – Information Security Read
- IT_DevOps – Development Operations
- mia.usa.sinvest\Application_Support – Application specific password operations
- mia.usa.sinvest\Globus_Miaprdr – Application specific password operations
- mia.usa.sinvest\Globus_Root – Application specific password operations
- mia.usa.sinvest\Globus_Support – Application specific password operations
- mia.usa.sinvest\HelpDesk_Support – Helpdesk support
- mia.usa.sinvest\IT_DevOps - Development Operations
- mia.usa.sinvest\IT_Operations_Support – Operations Support
- mia.usa.sinvest\ITGS
- mia.usa.sinvest\Root_Linux_PasswordSafe – Linux Administrators
- mia.usa.sinvest\Network_support – Network devices Administrators
- mia.usa.sinvest\IT_Protected_Development – Protected development servers
- mia.usa.sinvest\CyberArk_Aleros_Users – Third Party vendor/consultant users
- mia.usa.sinvest\PSG_printing – Use of local printers group
- mia.usa.sinvest\WKSTADMIN
- mia.usa.sinvest\BSI_DLP_AIP_SECRET
- mia.usa.sinvest\BSI_DLP_AIP_REST_CONF
- mia.usa.sinvest\Appian Admin Support
- mia.usa.sinvest\RPAAdmin_W_RDP_PRO
- mia.usa.sinvest\vsphere Administrators

3.3 Network Administration

- mia.usa.sinvest\CISCO ISE Administrators
- mia.usa.sinvest\CISCO Network Administrators
- mia.usa.sinvest\ISEAdmin
- mia.usa.sinvest\F5FullAdmin

3.4 MSSQL

- Users granted with the following fixed server roles: 'sysadmin'; 'serveradmin'; 'securityadmin'; 'setupadmin'; 'dbcreator'; 'bulkadmin'; 'processadmin'; 'diskadmin'
- Users granted with the following instance permissions: ADMINISTER BULK OPERATIONS'; 'ALTER'; 'ALTER ANY CREDENTIAL'; 'ALTER ANY CONNECTION'; 'ALTER ANY DATABASE'; 'ALTER ANY EVENT NOTIFICATION'; 'ALTER ANY ENDPOINT'; 'ALTER ANY LOGIN'; 'ALTER ANY LINKED SERVER'; 'ALTER RESOURCES'; 'ALTER SERVER STATE'; 'ALTER SETTINGS'; 'ALTER TRACE'; 'AUTHENTICATE SERVER'; 'CONTROL'; 'CONTROL SERVER'; 'CREATE ANY DATABASE'; 'CREATE DDL EVENT NOTIFICATION'; 'CREATE ENDPOINT'; 'CREATE TRACE EVENT NOTIFICATION'; 'IMPERSONATE'; 'SHUTDOWN'; 'TAKE OWNERSHIP'; and 'EXTERNAL ACCESS'
- Users granted with the following fixed database roles: 'db_accessadmin'; 'db_datawriter'; 'db_ddladmin'; 'db_owner'; 'db_securityadmin'; 'db_backupoperator'
- Users granted the following object permissions: "Alter"; "Control"; "Create"; "Delete"; "Insert"; "Take Ownership"; and "Update"
- Database owners
- Schema owners that own database objects

3.5 MYSQL

- Users granted with the following instance permissions: ALL [PRIVILEGES], 'ALTER'; 'ALTER ROUTINE'; 'CREATE', CREATE ROLE', CREATE ROUTINE', 'CREATE TABLESPACE, 'CREATE TEMPORARY TABLES', 'CREATE USER', 'DELETE', 'DROP', 'DROP ROLE', 'INSERT', 'LOCKED TABLES', 'PROXY, 'RELOAD', SHUTDOWN', 'SUPER' and 'UPDATE'. Refer to table below for more information on the grant table column and related context:

Privilege	Grant Table Column	Context
ALL [PRIVILEGES]	Synonym for "all privileges"	Server administration
ALTER	Alter_priv	Tables
ALTER ROUTINE	Alter_routine_priv	Stored routines

CREATE	Create_priv	Databases, tables, or indexes
CREATE ROLE	Create_role_priv	Server administration
CREATE ROUTINE	Create_routine_priv	Stored routines
CREATE TABLESPACE	Create_tablespace_priv	Server administration
CREATE TEMPORARY TABLES	Create_tmp_table_priv	Tables
CREATE USER	Create_user_priv	Server administration
DELETE	Delete_priv	Tables
DROP	Drop_priv	Databases, tables, or views
DROP ROLE	Drop_role_priv	Server administration
INSERT	Insert_priv	Tables or columns
LOCK TABLES	Lock_tables_priv	Databases
PROXY	See proxies_priv table	Server administration
RELOAD	Reload_priv	Server administration
SHUTDOWN	Shutdown_priv	Server administration
SUPER	Super_priv	Server administration
UPDATE	Update_priv	Tables or columns

3.6 Oracle

- Within the output for DBA_SYS_PRIVS; users granted with the following system privileges: *ALTER DATABASE; ALTER ANY PROCEDURE; ALTER ANY ROLE; ALTER ANY TABLE; ALTER PROFILE; ALTER SYSTEM; ALTER USER; BECOME USER; CREATE ANY CLUSTER; CREATE ANY TABLE; CREATE PROFILE; CREATE ROLE; CREATE USER; DELETE ANY TABLE; DROP ANY LIBRARY; DROP ANY*

PROCEDURE; DROP ANY ROLE; DROP ANY TABLE; DROP PROFILE; DROP TABLESPACE; DROP USER; GRANT ANY PRIVILEGE; GRANT ANY ROLE; INSERT ANY TABLE; RESTRICTED SESSION; or UPDATE ANY TABLE.

- Within the output for DBA_TAB_PRIVS, users having the following object privileges: INSERT; UPDATE; DELETE; or ALTER.
- Within the DBA_ROLE_PRIVS, users having the following roles: DBA; EXP_FULL_DATABASE; IMP_FULL_DATABASE; DELETE_CATALOG_ROLE; or RESOURCE.
- Within the V\$PWFFILE_USERS, users that are granted the 'SYSDBA' or 'SYSOPER' roles.

3.7 UNIX & Linux

- Within the /etc/passwd file, accounts having UID equivalent to '0' or GID equivalent to the root group GID.
 - UID = 0 gives the account full access to the OS and filesystem. This account can read, write and delete any file, shutdown or reboot the OS, add and remove users and groups and all other system administration tasks.
 - GID equivalent to root GID - these users also have elevated privileges which allow reading, writing and deletion of most files and administration of the OS.
- Within /etc/group file, members of root (GID 0) group.
 - Members of the GID 0 have elevated access allowing read/write to system files and administrative functions.
- Within the /etc/group file, members of the 'security' group
 - Members of security group have additional privileges to system files above regular users and can administrate certain aspects of the OS without having to have full root privilege. Delegation of user administration and access to system logs is typical use of this group.
- Within the /etc/security/user file, user account's 'admin' attribute is assigned to 'true'
 - This allows additional privileges if the user is considered an admin within the security files. Access to system files and administration of the OS can be delegated this way.
- Accounts with privileged Sudo access
 - This allows users to have elevated privileges, up to and including all commands via use of the sudo command. Privileges can be assigned explicitly to users directly in the file, and/or via group membership. Privileges can be restricted to certain commands, or can also allow root-like privileges without having to share the root password or put users into system groups.

3.8 Windows Local

- Windows Privileged Groups – All direct and enumerated members of local and domain groups within the local Administrators & Backup Operators groups.
 - Administrators - Members of the Administrators group have complete and unrestricted access to the computer, or if the computer is promoted to a domain controller, members have unrestricted access to the domain.

- Backup Operators - Members of the Backup Operators group can back up and restore all files on a computer, regardless of the permissions that protect those files. Backup Operators also can log on to and shut down the computer. This group cannot be renamed, deleted, or moved. By default, this built-in group has no members, and it can perform backup and restore operations on domain controllers

3.9 JBASE / T24 / GLOBUS

JBase is (www.jbase.com) - This flat file based database management system uses the local operating system file structure to assign permissions at the database layer. Access will be evaluated within:

- /etc/passwd, /etc/group, /etc/sudoers
- within the jsh console "LIST SYSTEM *A1 *A2 *A3 *A4 *A5 *A6 *A7"

Reporting and Escalation/Exceptions

Exceptions and breaches of this procedure must be escalated in accordance with the process outlined in the BSI IRM Policy and Standards & Compliance Management Standard.

The office of CIO / CISO will review and approve break glass requests based on the incident. Key Performance Indicator (KPI) Reporting is included in the monthly Operational Risk Management Dashboard which is presented to management at various risk forums.

4 RELATED DOCUMENTS

- Banco Santander International Information Risk Management Policy
- Banco Santander International Assurance Management - Policy and Standards & Compliance Management Standard
- Banco Santander International Asset Management Standard
- Banco Santander International Authentication and Authorization Standard
- Banco Santander International Identity and Access Management Standard
- Banco Santander International Application Portfolio Management Technical Standard
- Banco Santander International Application Portfolio Management Process

5 APPENDIX

5.1 Appendix A – Key Contacts

Title	Role	Name and Contact
Sr. Director	SHUSHA PAM Manager	Jim Lucas

5.2 Glossary

Term	Definition
Access Management (US)	US Access Management Team
Ansible	Software which automates privileged access processes (Privileged Access Termination)
CIO	Chief Information Officer
CISO	Chief Information Security Officer
Green List	Authorized list of privileged users
IRM	Information Risk Management
IT	Information Technology
PAM	Privileged Access Management
Managed Access List (White-List)	Pre-approved list of service (non-person) accounts and groups, which may be assigned to a system for Privileged Access as part of a standard server build definition without use of the Remedy process. There are a limited number of Legacy people-IDs which are also allowed to be propagated this way. These user-ids are also green-listed but due to a legacy technical issue, this small number of users are required to be whitelisted as well.